

Task 5

Prepared by :- Nandana Silju

Three Recent Malware Incidents

Summary, Attack Methods, and Mitigations 1)

Microsoft disruption of a Vanilla Tempest campaign (Rhysida /Oyster)

mid-October 2025 Threat actors (tracked as *Vanilla Tempest*) distributed fake Microsoft Teams installers signed with fraudulently obtained code-signing certificates. The installers dropped an Oyster backdoor and led to deployment attempts of Rhysida ransomware. Microsoft revoked over 200 fraudulent certificates and updated detection rules to block the campaign.

Attack method (chain):

- SEO poisoning / malicious search results lured victims to fake "Teams" download pages. - Victims downloaded a trojanized `MSTeamsSetup.exe` (appeared legitimate because it was signed). - The trojan executed a loader which installed the Oyster backdoor (signed). - Oyster provided persistent access and a foothold for deploying Rhysida ransomware and additional post-exploitation (credential theft, lateral movement).

Mitigation / resolution:

- Microsoft revoked more than 200 fraudulent code-signing certificates and published indicators of compromise.
- Defender protections were updated to detect the fake installers, Oyster, and Rhysida TTPs; customers were urged to enable/patch Defender and block the malicious domains.
- Organizations were advised to verify software download sources, use multi-factor authentication (MFA), and apply endpoint protection.

Fraudulent code signing undermines user trust in installers; rapid revocation and signature-blocklisting along with updated AV/EDR detections can neutralize large-scale signed-binary campaigns quickly.

2) CLOP extortion campaign exploiting Oracle E-Business Suite(CVE-2025-61882)

A critical, unauthenticated remote-code-execution zero-day in Oracle E-Business Suite (tracked as CVE-2025-61882) was exploited in the wild by actors claiming the CLOP extortion brand to exfiltrate data and send mass extortion demands to customers.

Multiple organizations (including higher-education and commercial victims) were impacted; Oracle issued emergency advisories and patches

Attack method (chain):

- Attackers scanned internet-facing Oracle EBS instances and exploited the unauthenticated RCE flaw (BI Publisher / Concurrent Processing integration). Successful exploitation allowed remote code execution and data access/exfiltration (no authentication required). - Stolen data was used for extortion emails and public leak threats; attackers aggregated victims for high-value ransom demands.

Mitigation / resolution:

- Oracle released out-of-band security advisories and emergency patches; vendors and CERTs (e.g., NCSC, Google/Mandiant tracking) published IOCs and mitigation guidance. Immediate action included applying vendor patches, isolating affected systems, and blocking malicious traffic. Security vendors published detection and patching guidance, and organisations performed forensic investigations and notified stakeholders as required. CrowdStrike, Rapid7 and others released technical writeups and scanning/IDS rules.

For widely-deployed enterprise apps, rapid disclosure + vendor patching plus coordinated intel sharing (CERTs, vendors, MSSPs) are essential to contain zero-day mass-exploitation and limit extortion impact.

3) BlackSuit "Blitz" — ransomware attack encrypting VMware ESXi hosts

A major manufacturing organization suffered a multi-stage intrusion that began with social engineering / stolen VPN credentials and culminated in BlackSuit (aka Royal/Chaos family) ransomware encrypting hundreds of VMs across ~60 VMware ESXi hosts. Unit 42 described the incident and response actions used to contain and remediate the attack.

Attack method (chain):

Initial access via vishing (voice phishing) and credential theft for remote VPN access. Attackers used the credentials to access the network, escalated privileges (DCSync/NTDS theft reported in similar cases), and deployed tools to move laterally. - The adversary used orchestration tools (Ansible) to push BlackSuit ransomware across ESXi hosts, encrypting many virtual machines at scale and causing major operational disruption.

Mitigation / resolution:

The victim engaged Unit 42 incident responders to contain and remediate: immediate containment, expansion of EDR coverage, automated playbooks for isolation, and forensic analysis to identify full scope. Unit 42 helped restore operations and provided strategic hardening recommendations (MFA on remote access, segmentation, improved logging/monitoring).

- Parallel law-enforcement operations (earlier coordinated takedowns and seizures against BlackSuit/Royal infrastructure) demonstrated one avenue for disrupting ransomware ecosystems; however, private incident response and improved internal controls were central to recovery for this victim.

Protecting virtualization infrastructure (ESXi/vCenter) is critical — attacks that reach hypervisors can create catastrophic blast radii. Strong remote-access controls (MFA), credential anti-abuse, segmentation, and tested IR playbooks are non-negotiable.

Practical recommendations (cross-incident)

- Enforce MFA on all remote access and critical admin accounts. - Keep software (especially internet-facing enterprise apps) patched and follow vendor emergency advisories.
- Use code-signing certificate monitoring and blocklisting to reduce risk from fraudulently signed malware. - Harden and monitor virtualization infrastructure (ESXi, vCenter), and isolate backups/offline copies.
- Invest in detection (EDR/XDR), incident response retainer/plan, and threat intel sharing (CERTs, ISACs)

References (selected sources)

- Microsoft Threat Intelligence / public posts and vendor writeups on the Vanilla Tempest / Rhysida campaign. - Rapid7 / CrowdStrike / Google Cloud Threat Intelligence writeups on CVE-2025-61882 and CLOP extortion activity.
- Unit 42 (Palo Alto Networks) "Anatomy of an Attack" on the BlackSuit incident and related mitigation notes.
- Reuters reporting on targeted organizations (Envoy/American Airlines) in the Oracle EBS extortion campaign.